devsu

PROPUESTA TÉCNICA DE ARQUITECTURA

Arquitectura de Solución para Banca por Internet

Diseño bajo el modelo C4, con seguridad, alta disponibilidad, auditoría y excelencia operativa para una banca digital moderna.

PREPARADO PARA	**BP** · Banca por Internet
PREPARADO POR	**Lic. Wilmer Ojeda** · Arquitecto de Soluciones
POSTULACIÓN	Arquitecto de Soluciones – Líder Técnico de Desarrollo · Devsu
CONTACTO	wilmerojeda@gmail.com | linkedin.com/in/lic-wilmer-ojeda
FECHA	Octubre, 2026

Índice

1. Resumen ejecutivo....3
2. Alcance y supuestos....4
3. Requerimientos....5
3.1 Funcionales....5
3.2 No funcionales....5
4. Marco normativo y estándares....6
5. Decisiones arquitectónicas y justificaciones....7
6. Modelo C4 – Nivel 1: Contexto....10
7. Modelo C4 – Nivel 2: Contenedores....11
8. Modelo C4 – Nivel 3: Componentes....13
8.1 Componentes del flujo de eventos (Auditoría y Notificaciones)....14
8.2 Patrones aplicados....15
9. Arquitectura de autenticación, autorización y onboarding....16
9.1 Flujo recomendado....16
9.2 Onboarding facial integrado al flujo de identidad....17
10. Auditoría y persistencia para clientes frecuentes....18
11. Capa de integración y servicios....19
12. Infraestructura Cloud, HA (High Availability) y DR (Disaster Recovery)....20
13. Seguridad....21
14. Monitoreo y excelencia operativa....23
15. Costos (estimación referencial mensual)....24
16. Riesgos y mitigación....25
17. Conclusiones....26
Anexo A. Selección de nube: justificación de AWS vs. Azure....27
A.1 Por qué se recomienda AWS....27
A.2 Mapeo de servicios AWS a Azure....28
A.3 Cuándo elegir Azure en lugar de AWS....28

1. Resumen ejecutivo

> **Rol:** Arquitecto de Soluciones · **Modelo:** C4 (Contexto, Contenedores, Componentes) · **Nube de referencia sugerida:** AWS

BP requiere un sistema de banca por internet que permita consultar el histórico de movimientos, realizar transferencias y pagos (entre cuentas propias e interbancarias) y notificar cada movimiento al cliente. La solución propuesta es una arquitectura **desacoplada, orientada a servicios y eventos**, con dos frontends (SPA y app móvil), una capa de integración (API Gateway + BFF), microservicios de dominio y una plataforma cloud multi-AZ con DR en segunda región (se ejecuta en varias zonas de disponibilidad y cuenta con una región alternativa para la recuperación ante desastres).

Criterios de diseño de la plataforma:

- **Seguridad por diseño** (Zero Trust, cifrado extremo a extremo, autenticación fuerte).
- **Desacoplamiento** mediante eventos, de modo que nuevos servicios se agreguen sin modificar los existentes.
- **Resiliencia:** Circuit Breaker (si un servicio falla repetidamente, deja de enviarle solicitudes por un tiempo para evitar sobrecargarlo y permitir que se recupere), Saga (la operación se divide en transacciones locales; si un paso falla, se ejecutan acciones compensatorias para corregir los pasos anteriores. **Ejemplo de fallo:** se debita el importe, pero el banco receptor rechaza la transferencia. La Saga ordena devolver el importe a la cuenta y notificar al cliente del rechazo y la reversión), **reintentos idempotentes** (el sistema puede repetir una solicitud después de un error sin ejecutar la operación más de una vez) y **autohealing** (recuperación automática: la plataforma detecta ciertos fallos y toma medidas automáticamente, como reiniciar un servicio o reemplazar una instancia defectuosa).
- **Auditabilidad total** con registro inmutable de las acciones en las diferentes capas de la aplicación relativas a las transacciones de los clientes dentro de todo el sistema.
- **Costo controlado** con autoescalado (aumenta o reduce automáticamente los recursos según el uso), capacidad reservada (se contrata por anticipado una cantidad de recursos que se usan de forma constante) y almacenamiento por niveles (guarda la información según cuánto se consulta: los datos recientes o de acceso frecuente quedan en almacenamiento rápido; los históricos poco consultados pueden pasar a opciones más económicas).

2. Alcance y supuestos

Alcance: banca web y móvil para clientes; onboarding digital con reconocimiento facial en móvil; posibilidad de **Consulta, Transferencias, Pagos y Notificaciones** como módulos básicos solicitados; se incorpora **Antifraude y Límites** como módulo adicional propuesto.

Supuestos:

- El core bancario expone APIs (REST/SOAP) o un bus corporativo; no se modifica.
- Existe un sistema complementario de información detallada del cliente (CRM/datos ampliados) accesible por API.
- La compañía dispone de un producto IAM compatible con OAuth 2.0 / OpenID Connect. En la práctica, el cliente inicia sesión a través del IAM y la aplicación recibe tokens para verificar su identidad y gestionar el acceso.
- La transferencia interbancaria se liquida contra la red de pagos del país (ej. BCE/SPI) a través del core o un conector dedicado. **BP valida y carga la cuenta, y luego el core o el conector envía la instrucción a la red interbancaria para que llegue al otro banco.**

3. Requerimientos

3.1 Funcionales

- RF1 Consultar datos básicos y detallados del cliente.
- RF2 Consultar histórico de movimientos con filtros y paginación.
- RF3 Transferencias entre cuentas propias e interbancarias.
- RF4 Pagos (servicios, tarjetas, terceros).
- RF5 Antifraude y límites (validar operaciones por clientes / montos).
- RF6 Notificar cada movimiento por al menos dos canales.
- RF7 Onboarding con reconocimiento facial y prueba de vida.
- RF8 Login con usuario/clave, biometría del dispositivo u otro factor.
- RF9 Auditar todas las acciones del cliente.

3.2 No funcionales

Atributo	Objetivo
Disponibilidad	99.95 % mensual
RTO / RPO	RTO ≤ 30 min, RPO ≤ 5 min (transaccional: ≈ 0 en la misma región). En conjunto: se busca recuperar el servicio en media hora y limitar la pérdida potencial de datos a cinco minutos; para las transacciones en la región principal, se pretende una pérdida prácticamente nula
Latencia	p95 consultas < 500 ms (95 % de las consultas debería responder en menos de 500 milisegundos); transferencias < 2 s (la parte de la operación que controla BP debería tardar menos de 2 segundos, sin contar el tiempo que tarde la red externa de pagos en liquidarla)
Escalabilidad	Horizontal (aumentar la capacidad agregando más instancias de un servicio), autoescalado por CPU (cuánto procesamiento están usando las instancias) / RPS (cuántas solicitudes recibe el sistema por segundo) / lag de colas (cuánto se están demorando los mensajes en una cola, normalmente porque se acumulan más rápido de lo que se procesan)
Seguridad	OWASP ASVS L2 (nivel de verificación de seguridad para la aplicación web) / MASVS L2 (referencia de seguridad para la aplicación móvil), PCI-DSS (**Payment Card Industry Data Security Standard**), cifrado AES-256 (algoritmo de cifrado simétrico para los datos) y TLS 1.2+ (TLS versión 1.2 o superior para proteger las comunicaciones entre el usuario y la plataforma)
Auditoría	Registro inmutable; retención de registros según su categoría y normativa aplicable: como referencia, archivos contables digitales por al menos 15 años y registros sujetos a la normativa antilavado por 10 años
Observabilidad	Métricas (latencia, errores, uso de CPU o transferencias procesadas, etc.), logs (registros detallados de eventos, como una autenticación fallida o una transferencia rechazada) y trazas correlacionadas que muestran el recorrido de una solicitud por varios servicios. Un identificador compartido `traceId` permite relacionar los registros y tramos de una misma operación; alertas por SLO - Service Level Objective (avisan cuando el servicio se acerca a incumplir un objetivo acordado, como responder consultas en cierto tiempo o mantener una disponibilidad determinada)

4. Marco normativo y estándares

Nota: validar vigencia y detalle con el área legal y de cumplimiento de BP.

Norma / estándar	Aplicación en la solución
Ley Orgánica de Protección de Datos Personales (LOPDP, Ecuador)	Consentimiento, minimización, derechos ARCO, notificación de brechas, tratamiento de datos biométricos (datos sensibles), cifrado y seudonimización.
Superintendencia de Bancos y Junta de Política y Regulación Financiera	Normas de gestión de riesgo operativo, seguridad de la información, canales electrónicos, continuidad del negocio y notificación al cliente de transacciones.
Ley de Comercio Electrónico, Firmas y Mensajes de Datos	Validez de transacciones y evidencias electrónicas, no repudio (contar con evidencia fiable de que una persona realizó o autorizó una acción, para que después no pueda negar fácilmente haberlo hecho). Por ejemplo, se conservarían evidencias que vinculen la operación con el cliente: autenticación utilizada, fecha y hora, datos de la orden, confirmación y registros inmutables.
PCI-DSS v4.0	Datos de tarjeta: tokenización (sustituir el número real de la tarjeta por un token), segmentación de red (aislar los sistemas que manejan datos de tarjetas del resto de la plataforma, restringiendo las comunicaciones entre ellos), gestión de claves (proteger las claves criptográficas: controlar quién puede usarlas, almacenarlas de forma segura y renovarlas cuando corresponda).
ISO/IEC 27001 y 27002	Estándares internacionales relacionados con la seguridad de la información (Sistema de gestión de seguridad de la información, SGSI).
ISO 22301	Continuidad del negocio y DR. Ayuda a una organización a prepararse para interrupciones, responder a ellas y mantener o recuperar sus servicios dentro de plazos definidos.
OWASP ASVS / MASVS / API Security Top 10	Requisitos de seguridad para web, móvil y APIs.
NIST SP 800-63B	Niveles de aseguramiento de autenticación (AAL2 mínimo; exige comprobar la identidad usando **dos factores distintos**).
ISO/IEC 30107	Evaluación de ataques de presentación (liveness) en biometría facial. Es una familia de estándares para detectar y evaluar **ataques de presentación biométrica**: intentos de engañar al sensor con una foto, un video o una máscara, por ejemplo.

5. Decisiones arquitectónicas y justificaciones

#	Decisión	Alternativas evaluadas	Justificación 1	Justificación 2
D1	**SPA (Single Page Application) en Angular**	React, Vue	Framework opinado con DI (*dependency injection*: los componentes reciben los servicios que necesitan), routing, formularios reactivos y tipado fuerte (TypeScript), lo que **hace que los equipos sigan las mismas convenciones y organicen el código de forma similar**.	Mantenibilidad a largo plazo y soporte LTS con actualizaciones predecibles, valioso en banca.
D2	**Móvil en Flutter**	React Native, Kotlin Multiplatform	Un solo código con render propio y rendimiento cercano a nativo; UI consistente en Android/iOS.	Plugins maduros para biometría local, cámara/liveness, Keystore/Keychain (para guardar datos pequeños y sensibles, como tokens de inicio de sesión) y certificate pinning (además de comprobar que la conexión HTTPS sea válida, la app verifica que el servidor use un certificado, o una clave pública, que reconoce de antemano; si no coincide, rechaza la conexión). React Native sería válida si el equipo ya domina React/JS.
D3	**OAuth 2.0 Authorization Code + PKCE** (OIDC) para SPA y móvil	Implicit, Password (ROPC), Client Credentials	Implicit y ROPC están desaconsejados por OAuth 2.1 / RFC 9700: exponen tokens o credenciales a la app.	PKCE protege clientes públicos (SPA/móvil) frente a interceptación del código.
D4	**IAM corporativo configurado** (no desarrollo propio)	Construir servidor OAuth propio, Cognito/Azure AD B2C	Reutiliza producto existente: menor costo y riesgo criptográfico.	Centraliza políticas de MFA (Multi Factor Authentication), sesiones, revocación y federación para canales futuros. La app solicita un token de acceso para llamar al BFF o las APIs; esos servicios validan el token y aplican los permisos correspondientes.
D5	**Autenticación: usuario+clave y biometría local con passkeys (FIDO2)**	OTP SMS, solo contraseña	Passkeys resisten phishing y evitan SIM swap (fraude en el que alguien convence a la operadora de transferir tu número de teléfono a una SIM o eSIM que controla), que afecta al OTP por SMS.	Biometría desbloquea una clave privada en el dispositivo (Secure Enclave/StrongBox): la huella nunca sale del equipo.
D6	**Onboarding facial con proveedor especializado** (AWS Rekognition Face Liveness + face match contra cédula; alternativas Onfido/Jumio)	Desarrollo propio con modelos open source	Liveness certificado y mitigación de deepfakes/ataques de presentación (ISO 30107).	Reduce tiempo de salida y evita custodiar modelos biométricos propios; cumple LOPDP con minimización.

#	Decisión	Alternativas evaluadas	Justificación 1	Justificación 2
D7	**API Gateway + BFF (web y móvil)**	Acceso directo a microservicios, GraphQL único	Gateway centraliza WAF (filtra solicitudes web maliciosas), rate limit (limita cuántas solicitudes puede hacer un usuario o cliente en cierto período, para reducir abusos y sobrecargas), autenticación JWT (el Gateway valida el token recibido) y versionado (dirige las solicitudes a la versión correcta de la API, por ejemplo `/v1` o `/v2`, para permitir cambios sin interrumpir a los clientes que aún usan una versión anterior).	BFF adapta payloads por canal (menos llamadas, menor latencia móvil) y desacopla la evolución de los frontends. El BFF traduce entre lo que solicita cada frontend y las APIs internas.
D8	**Microservicios por capacidad de negocio**	Monolito modular	Escalado y despliegue independientes (movimientos escala distinto a transferencias).	Aislamiento de fallos y límites claros que facilitan agregar servicios futuros.
D9	**Mensajería asíncrona** (Amazon MSK/Kafka; SQS/SNS para notificaciones)	RabbitMQ, llamadas síncronas	Desacoplan productores y consumidores. Por ejemplo, un evento `TransferenciaCompletada` podría alimentar notificaciones, analítica y reportes; absorbe picos (load leveling: la cola almacena temporalmente mensajes cuando llegan más rápido de lo que el consumidor puede procesarlos).	Kafka, al retener eventos, permite reprocesar y alimentar auditoría y analítica.
D10	**Saga orquestada para transferencias**	2PC/XA	2PC no escala ni es viable con sistemas externos.	**Las compensaciones permiten corregir cada paso si algo falla, dejando un registro claro y manteniendo los datos sincronizados.**
D11	**Auditoría con Event Sourcing + CQRS**	Triggers en BD, logs de aplicación	Registro append-only e inmutable, con reconstrucción del historial.	**Separa las consultas de auditoría de las operaciones que modifican datos, para consultar el historial sin afectar las transacciones.**
D12	**Cache-Aside con Redis** para clientes frecuentes	Read-through, caché local	Reduce carga y latencia sobre el core (TTL y evicción controlados: se decide cuánto duran los datos y cómo se liberan cuando hace falta espacio).	Cache-Aside tolera caída de Redis (degrada a core) y es simple de invalidar por eventos (cuando ocurre un cambio, por ejemplo se actualiza un usuario, el sistema **borra o marca como obsoleto el dato guardado en caché**). La consulta puede tardar más y aumentar la carga del core, pero no se detiene por completo.

#	Decisión	Alternativas evaluadas	Justificación 1	Justificación 2
D13	**Notificaciones multicanal con failover** (Push FCM (*Firebase Cloud Messaging*) / APNs (*Apple Push Notification service*), SMS/Email por proveedor A y B)	Un único proveedor	Cumple el mínimo de dos sistemas y evita punto único de falla.	Patrón Strategy + Circuit Breaker permite conmutar proveedor automáticamente. Intenta con el proveedor principal; si devuelve un error recuperable o agota el tiempo de espera, intenta con el alternativo. **Circuit Breaker** registra fallos por proveedor: si se acumulan, "abre el circuito" y deja de enviarle temporalmente, así se evita esperar a que falle en cada intento. Tras un intervalo, permite una prueba y, si funciona, vuelve a usarlo.
D14	**AWS como nube** (EKS, Aurora, MSK, ElastiCache)	Azure (AKS, Azure SQL, Event Hubs)	Madurez de servicios gestionados multi-AZ y regiones cercanas (São Paulo, Virginia) para baja latencia en Ecuador.	Rekognition Liveness e integración nativa con WAF/KMS/Shield simplifican el stack. Azure sería el equivalente funcional si BP ya tiene contrato.
D15	**Kubernetes (EKS) multi-AZ**	ECS Fargate, Lambda	Autohealing (comprueba si los contenedores están vivos y listos para recibir tráfico; si uno falla, puede reiniciarlo o dejar de enviarle solicitudes temporalmente), HPA (aumenta o reduce automáticamente la cantidad de réplicas según métricas, como el uso de CPU o memoria) y despliegues progresivos (publican una versión nueva gradualmente, por ejemplo actualizando unas réplicas a la vez; si algo falla, se puede detener el despliegue o volver a la versión anterior).	Portabilidad y estandarización de operación entre entornos.
D16	**Infraestructura como código (Terraform) y GitOps**	Consola manual	Reproducibilidad y DR repetible.	Auditabilidad de cambios y reducción de error humano.

6. Modelo C4 – Nivel 1: Contexto

Actores y sistemas

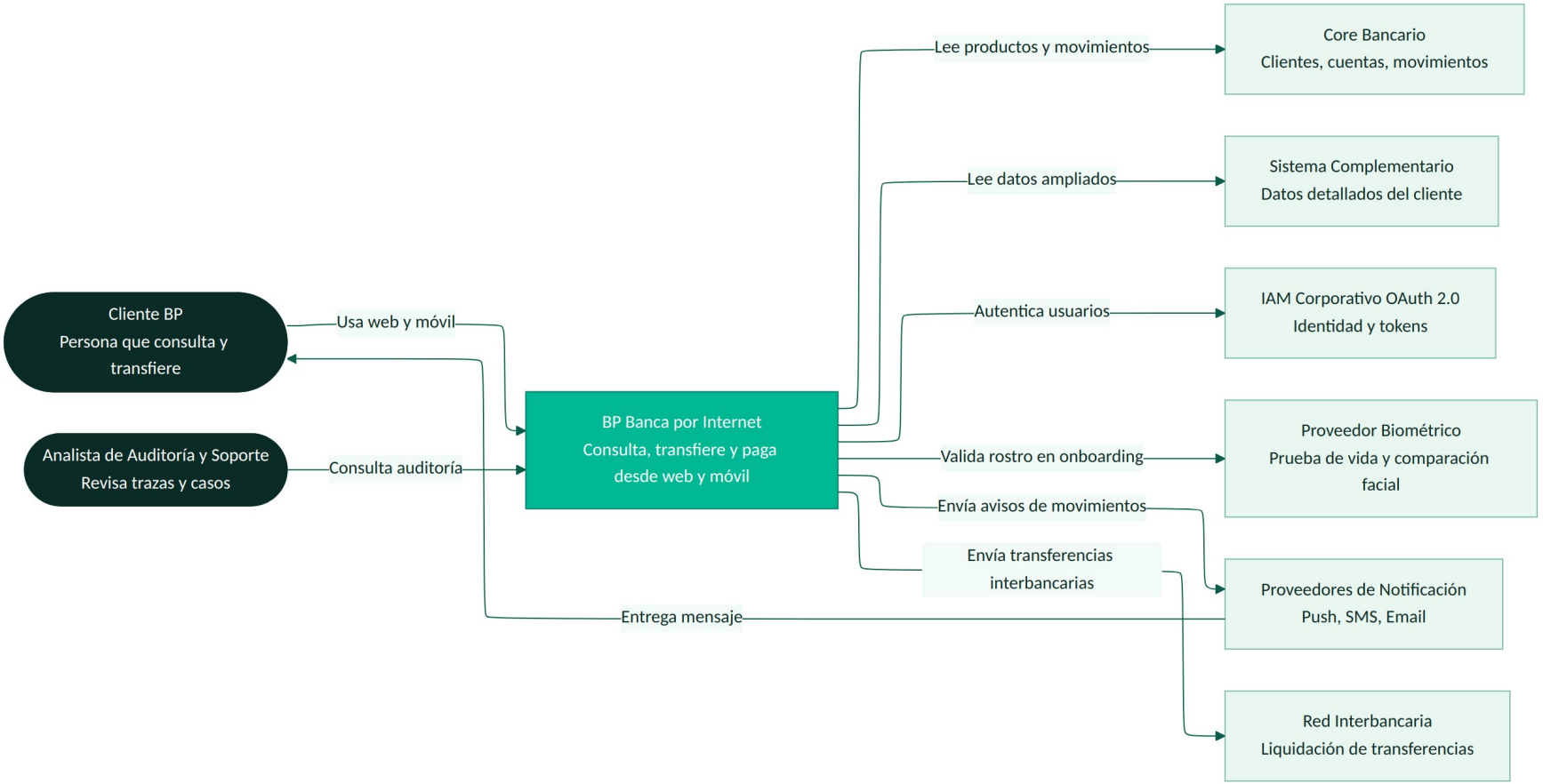


Figura 1. Diagrama de contexto (C4 – Nivel 1)

7. Modelo C4 – Nivel 2: Contenedores

Aplicaciones, servicios, datos y mensajería.

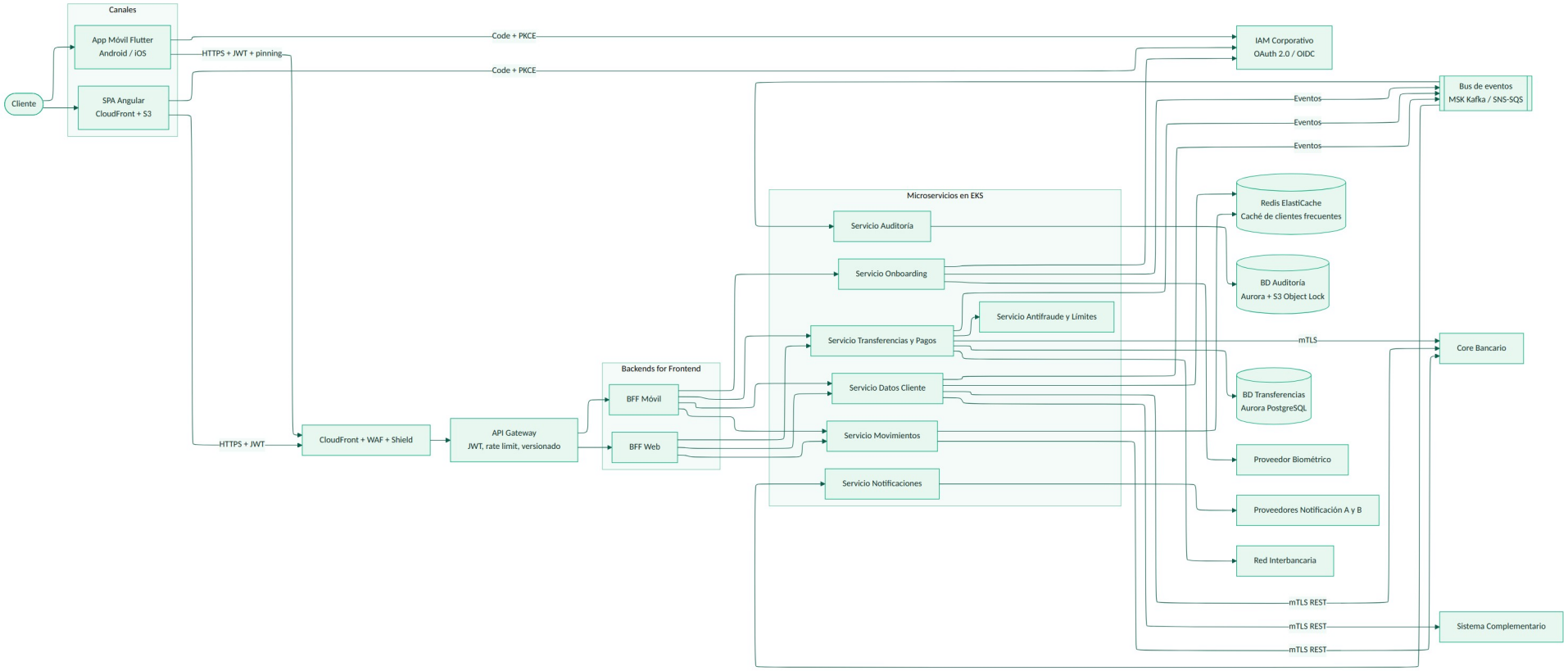


Figura 2. Diagrama de contenedores (C4 – Nivel 2)

Descripción de contenedores nuevos (más allá de los tres iniciales):

- **Antifraude y Límites:** reglas y scoring en línea (monto, dispositivo, horario, beneficiario nuevo). Reduce fraude y habilita step-up de autenticación.
- **Notificaciones:** consume eventos, aplica preferencias del cliente y envía por canal con failover.
- **Auditoría:** consume todos los eventos y registra de forma inmutable.
- **Onboarding:** orquesta captura, liveness, face match y alta de identidad.
- **Caché de cliente frecuente:** reduce las lecturas repetidas al core.

8. Modelo C4 – Nivel 3: Componentes

Se detalla el servicio crítico de Transferencias y Pagos y el flujo de eventos.

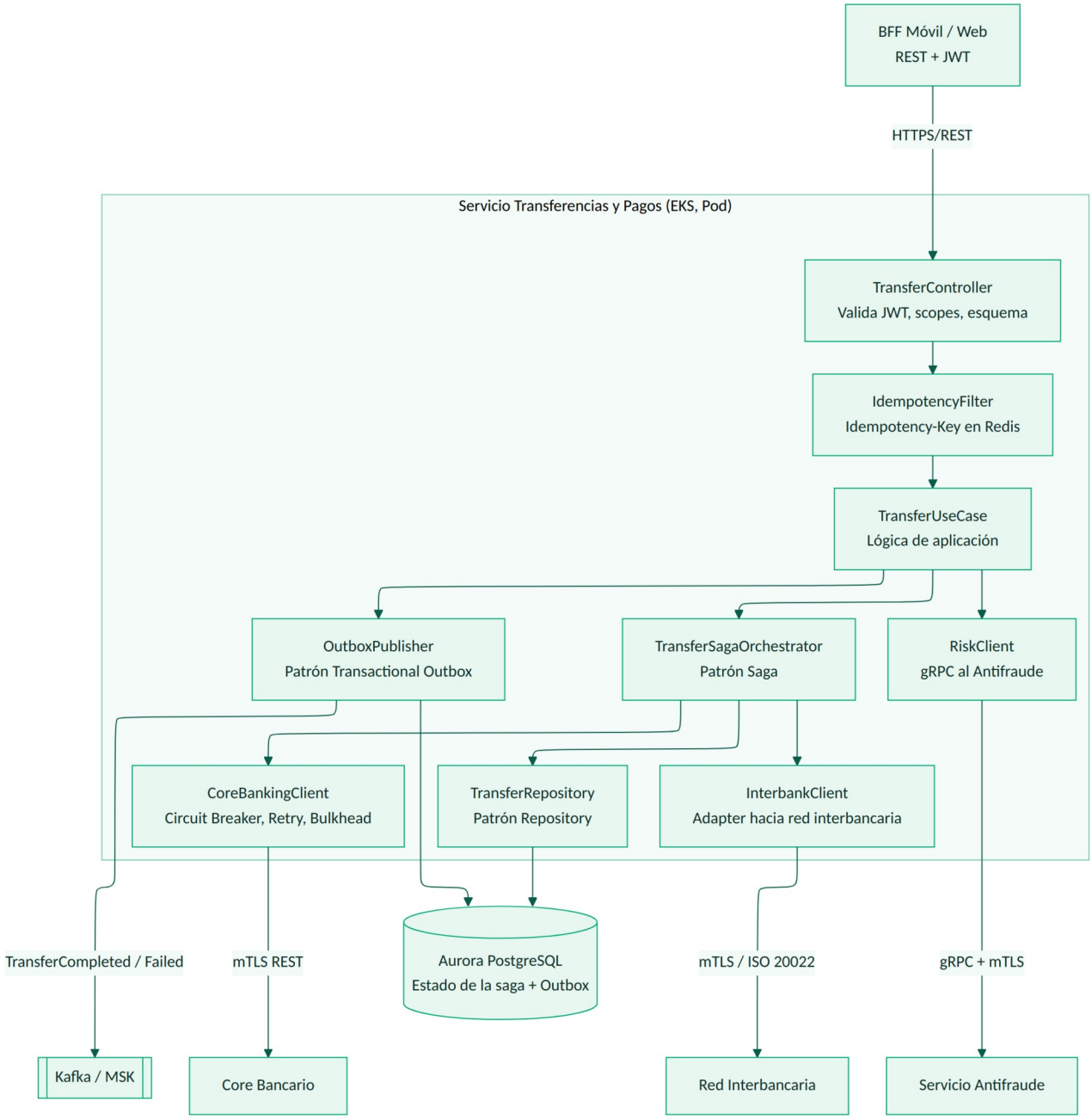


Figura 3. Diagrama de componentes: Servicio de Transferencias y Pagos (C4 – Nivel 3)

8.1 Componentes del flujo de eventos (Auditoría y Notificaciones)

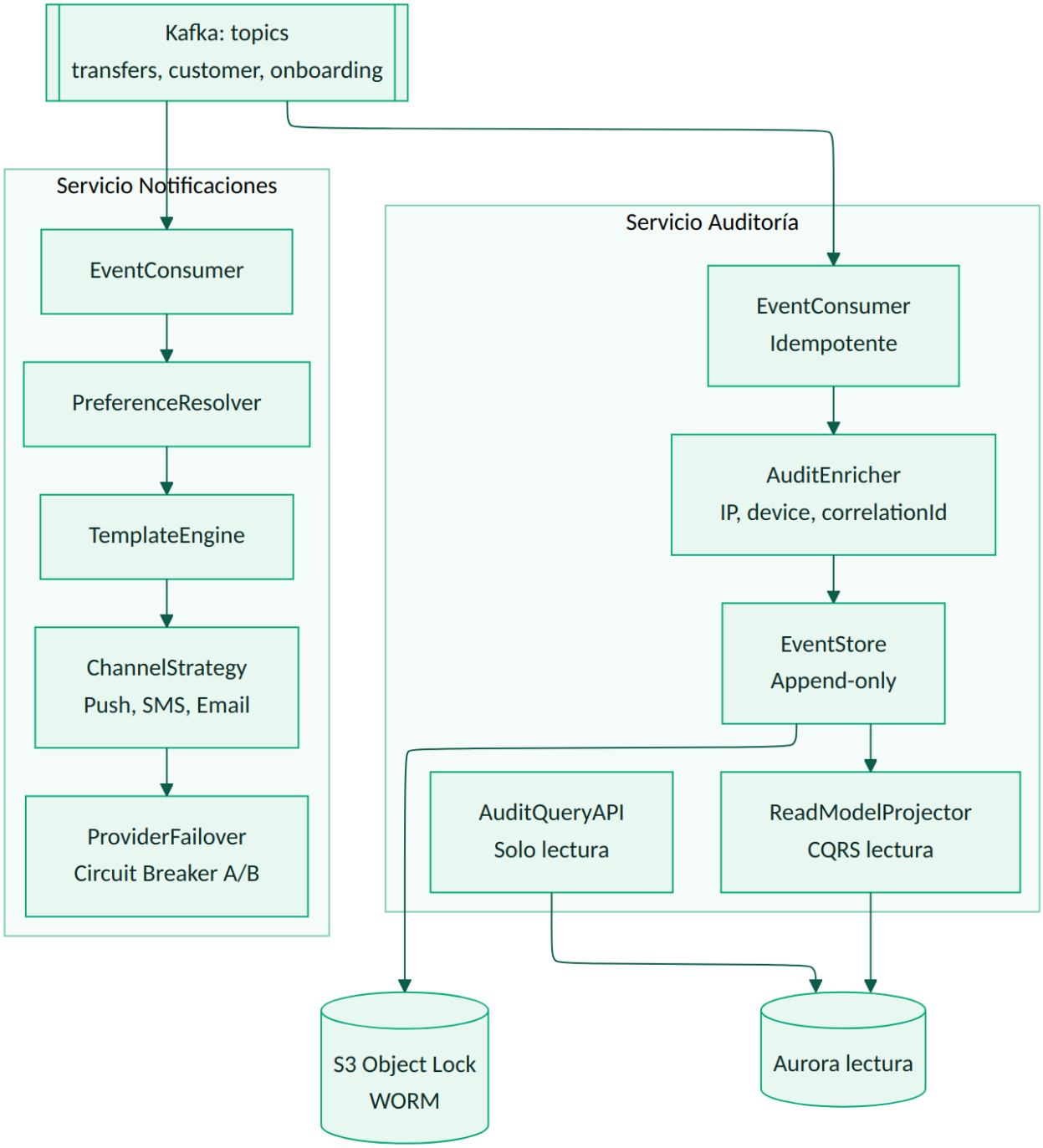


Figura 4. Diagrama de componentes: Auditoría y Notificaciones (C4 – Nivel 3)

8.2 Patrones aplicados

Patrón	Dónde	Beneficio
API Gateway / BFF	Entrada	Seguridad central y APIs por canal
Circuit Breaker, Retry, Bulkhead, Timeout	Clientes al core y externos	Evita fallas en cascada
Saga (orquestada)	Transferencias	Consistencia eventual con compensación
Transactional Outbox	Publicación de eventos	Evita pérdida de eventos (escritura atómica)
Idempotency Key	POST de transferencias	Reintentos seguros
Cache-Aside	Datos de cliente y movimientos recientes	Menor latencia y carga al core
Repository	Acceso a datos	Aísla persistencia del dominio
CQRS + Event Sourcing	Auditoría	Inmutabilidad y consulta eficiente
Strategy + Adapter	Notificaciones e integraciones	Cambiar proveedor sin tocar el dominio
Anti-Corruption Layer	Cliente del core y sistema complementario	Protege el dominio de modelos legados, evitando que las formas antiguas de nomenclatura de datos se propaguen por el código nuevo.
Hexagonal (puertos y adaptadores)	Cada microservicio	Cohesión y pruebas aisladas. Aísla la lógica del negocio de las tecnologías externas mediante interfaces y conectores intercambiables.

9. Arquitectura de autenticación, autorización y onboarding

9.1 Flujo recomendado

- **Flujo:** *Authorization Code con PKCE (S256)* + OpenID Connect para SPA y móvil.
- **Tokens:** access token JWT de corta vida (5–10 min), refresh token rotativo con detección de reutilización; en SPA se evita guardar tokens en localStorage (usar BFF con cookie HttpOnly/SameSite o memoria).
- **Móvil:** navegador del sistema (ASWebAuthenticationSession / Custom Tabs), almacenamiento en Keychain/Keystore (guardar credenciales y otros datos sensibles en el almacenamiento seguro del sistema operativo), certificate pinning (verificar que la conexión HTTPS sea con el servidor esperado) y detección de root/jailbreak (comprobar si el dispositivo está modificado y, según el riesgo, limitar funciones o reforzar controles).
- **Autorización:** scopes y claims (`accounts:read`, `transfers:write`); políticas de montos con **step-up** (reautenticación biométrica/OTP) para operaciones de riesgo.
- **Servicio a servicio:** Client Credentials + mTLS (**autenticación segura entre servicios mediante tokens y certificados mutuos**).

9.2 Onboarding facial integrado al flujo de identidad

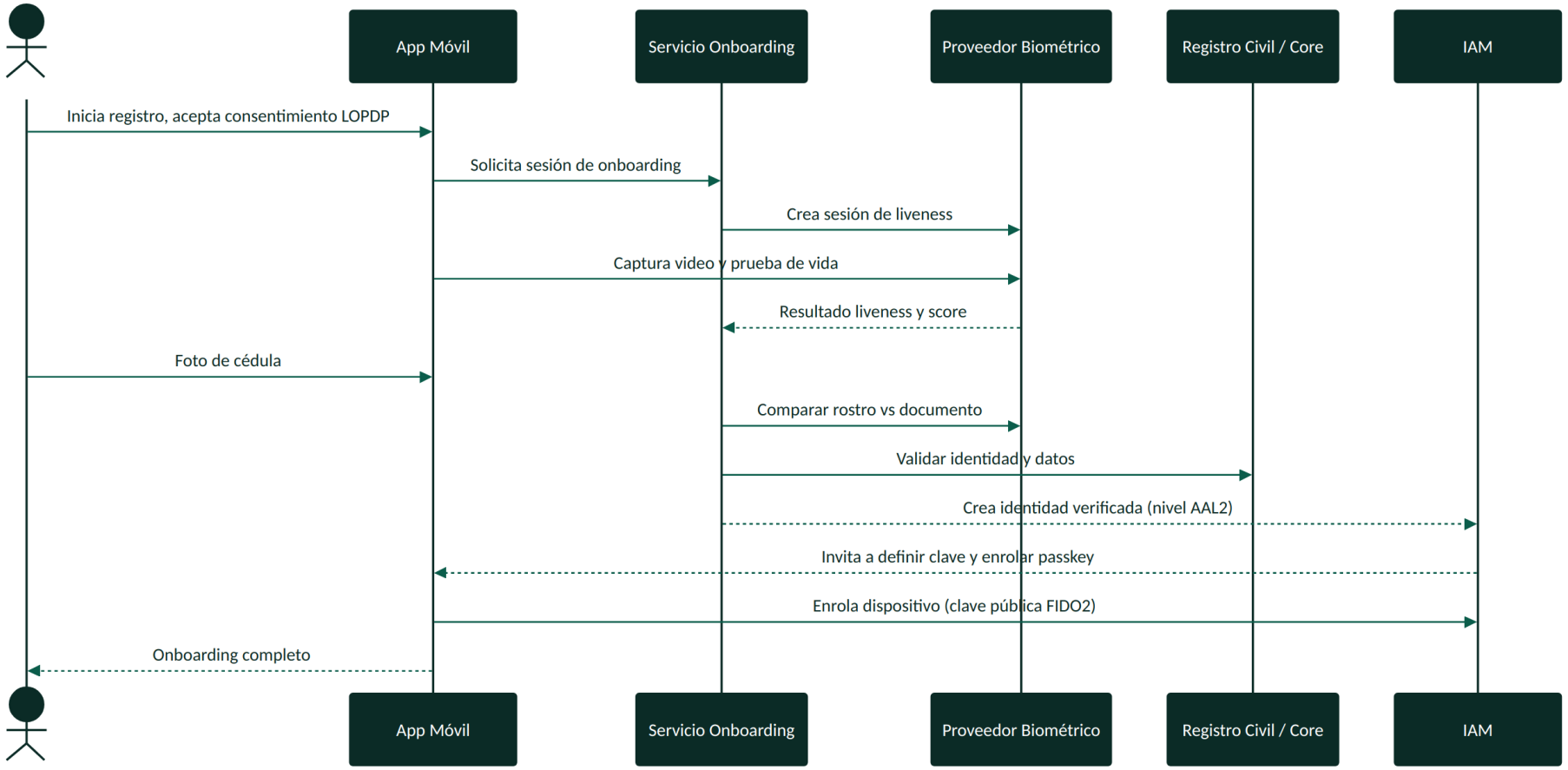


Figura 5. Secuencia de onboarding facial integrado a la identidad

- El resultado biométrico se guarda como **evidencia mínima** (score, hash, timestamp), con la imagen cifrada y retención limitada.
- A partir del alta, el usuario ingresa con **usuario + clave** y **huella/Face ID** (passkey FIDO2 ligada al dispositivo); en equipos nuevos se exige reverificación.
- Herramientas que robustecen: **AWS Rekognition Face Liveness** (comprueban a la persona), Onfido/Jumio (servicios de **verificación de identidad**: suelen revisar documentos oficiales y comparar la foto del documento con un selfie o una prueba de vida), **Firebase App Check / Play Integrity / App Attest** (ayudan a verificar que las solicitudes provienen de una app auténtica y, según la plataforma, de un entorno o dispositivo confiable), **RASP** (Guardsquare, Talsec: protección que se ejecuta dentro de la app; puede detectar señales de manipulación, depuración, instrumentación o ejecución en un dispositivo comprometido, y permitir bloquear o limitar acciones), **Device Fingerprint** (ej. ThreatMetrix: reúne señales del dispositivo y su entorno para estimar si parece conocido, sospechoso o relacionado con fraude) y SAST/DAST en el pipeline (pruebas de seguridad automatizadas integradas en el proceso de desarrollo: **SAST** analiza el código sin ejecutarlo; **DAST** prueba la aplicación mientras está funcionando, en ambiente de pruebas, buscando fallos observables desde fuera).

10. Auditoría y persistencia para clientes frecuentes

Propuesta: combinación de **Event Sourcing + CQRS + Cache-Aside + Repository**.

1. Cada acción del cliente (login, consulta, transferencia, cambio de datos) genera un **evento de dominio** con `correlationId`, usuario, IP, dispositivo y resultado.
2. El evento se publica vía **Transactional Outbox** al bus y el **Servicio Auditoría** lo almacena en un **Event Store append-only** (Aurora + copia WORM en S3 Object Lock).
3. Un **Projector** construye un **modelo de lectura** (CQRS) para consultas de auditoría y cumplimiento, sin impactar el flujo transaccional.
4. Para **clientes frecuentes**, el servicio de Datos Cliente aplica **Cache-Aside** en Redis: **si el dato no está en Redis, consulta el core o el sistema complementario y guarda el resultado en Redis durante un tiempo limitado (TTL). Cuando el dato cambia, se elimina de la caché para que la próxima consulta cargue la versión actualizada.**
5. La frecuencia se calcula con contadores deslizantes en Redis; los clientes calientes se **precargan** (cache warming) fuera de horas pico.

Justificaciones: (a) el registro inmutable satisface no repudio y trazabilidad regulatoria; (b) separar lectura y escritura permite escalar la auditoría independientemente; (c) la caché reduce la carga y el costo del core y mejora la experiencia. Si Redis falla, el sistema continúa consultando el core, aunque puede responder más lentamente.

11. Capa de integración y servicios

Servicio	Responsabilidad	Integración
Datos Cliente	Datos básicos (core) + detalle (sistema complementario) con composición y caché	REST mTLS, ACL
Movimientos	Histórico paginado, filtros, caché de recientes	REST mTLS, cursor pagination
Transferencias y Pagos	Orquestación de transferencias propias/interbancarias y pagos	REST/ISO 20022, Saga
Antifraude y Límites (propuesto)	Scoring (calcula el riesgo usando señales de la operación y del cliente; según el resultado, se aprueba, se rechaza o se envía a revisión/autenticación adicional), límites diarios, listas de control (bloqueos)	gRPC síncrono + eventos
Notificaciones	Push/SMS/Email con failover	Consumidor de eventos
Auditoría	Event store y consulta	Consumidor de eventos
Onboarding	Orquesta liveness, face match y alta	REST + proveedor biométrico
Catálogos y Preferencias (futuro)	Bancos, tarifas, preferencias del cliente	REST con caché

Resiliencia en integración: timeouts cortos, reintentos con backoff (esperar más tiempo antes de cada nuevo intento; por ejemplo, 1 segundo, luego 2 y después 4) y *jitter* (añadir una pequeña variación aleatoria a esos tiempos, para que muchos servicios no reintenten exactamente a la vez), Circuit Breaker, Bulkhead por dependencia (separar recursos, por ejemplo conexiones o límites de concurrencia, para que una dependencia saturada no agote los recursos de toda la aplicación), colas de reintento (DLQ: guardar trabajos fallidos para procesarlos más tarde) y modo degradado (por ejemplo, mostrar últimos movimientos en caché si el core no responde).

12. Infraestructura Cloud, HA (High Availability) y DR (Disaster Recovery)

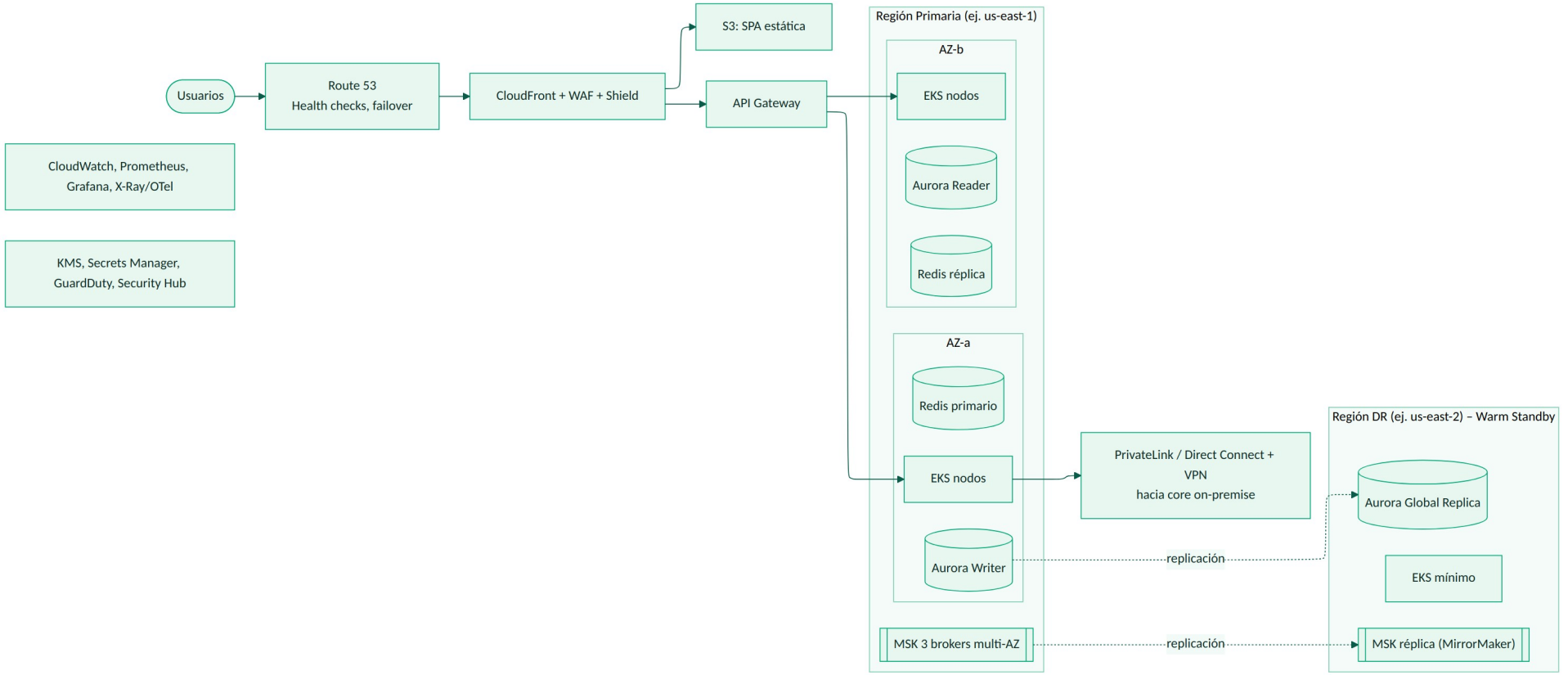


Figura 6. Arquitectura de infraestructura en AWS: multi-AZ y DR en segunda región

- **Alta disponibilidad:** mínimo 3 AZ, pods con *anti-affinity* (evitar que réplicas de un mismo servicio queden en el mismo nodo o zona), PodDisruptionBudgets (limitar cuántos pods pueden interrumpirse a la vez durante tareas voluntarias, como mantenimiento o actualizaciones), Aurora Multi-AZ, Redis con failover automático, MSK multi-AZ (distribuir el sistema de mensajería Kafka entre centros de datos separados).
- **Tolerancia a fallos:** patrones de resiliencia, DLQ (cola de mensajes fallidos que no pudieron procesarse tras varios intentos), colas para absorber picos (guardan temporalmente solicitudes cuando llegan más rápido de lo que el servicio puede procesarlas) y modo degradado (mantiene disponible una parte útil del producto si una dependencia falla, por ejemplo, mostrar datos en caché).
- **Recuperación de desastres:** *Warm Standby* (versión reducida pero funcional de la infraestructura) en segunda región con Aurora Global Database, réplica de topics (replica mensajes de Kafka entre regiones) y de S3 (CRR: copia objetos de un bucket a otro en otra región); IaC permite recrear de forma repetible los componentes que no están ya preparados en la región secundaria (como servicios, permisos y configuración); pruebas semestrales de DR y *game days* (simulacros controlados de fallos).
- **Autohealing:** liveness (Kubernetes comprueba si el proceso sigue funcionando; si falla repetidamente, reinicia el contenedor) / readiness (indica si el pod está listo para recibir tráfico; si falla, se lo retira temporalmente del balanceo, pero no necesariamente se reinicia) / startup probes (da tiempo a que una aplicación tarde en arrancar; mientras la comprobación no pase, Kubernetes no aplica las de liveness y readiness), reemplazo automático de nodos cuando falta capacidad o un nodo deja de estar disponible (Auto Scaling Group/Karpenter), ajuste en la cantidad de réplicas de pods mediante HPA (aumenta de manera horizontal según métricas: CPU, memoria, etc.) y KEDA (permite escalar en función de eventos o métricas de sistemas externos/internos), reinicios controlados (despliegues graduales y reinicios coordinados para evitar interrumpir todas las réplicas a la vez) y runbooks automatizados (AWS Systems Manager: procedimientos para responder a incidentes, por ejemplo reiniciar un servicio o ejecutar una verificación, que pueden automatizarse bajo condiciones definidas).
- **Baja latencia:** CloudFront en el borde, regiones cercanas y caché Redis.

13. Seguridad

- **Perímetro:** WAF (*Web Application Firewall*), OWASP (*Open Worldwide Application Security Project*) Top 10, bots (reglas especializadas ayudan a identificar o limitar automatizaciones abusivas), Shield (servicio de AWS para mitigar ataques), rate limiting (limita la cantidad de solicitudes en un intervalo).
- **Zero Trust:** mTLS entre servicios (service mesh Istio/App Mesh: cliente y servidor presentan certificados para autenticarse, y el tráfico viaja cifrado), políticas de red (establecen qué pods pueden comunicarse entre sí y con qué destinos) e IAM por rol (IRSA: un pod obtiene solo los permisos de AWS que necesita, en vez de compartir credenciales amplias).
- **Datos:** TLS 1.2+/1.3 (cifra la comunicación entre componentes para que terceros no puedan leer fácilmente los datos en tránsito); AES-256 con KMS (cifra datos usando AES con claves gestionadas por AWS KMS); CMK por dominio (separar claves por área funcional o tipo de datos, para limitar el impacto de un acceso indebido y permitir políticas distintas); tokenización de PAN (reemplaza el número de tarjeta, *Primary Account Number*, por un token); enmascaramiento en logs (oculta o elimina datos sensibles antes de registrarlos); secretos en Secrets Manager con rotación (**cambiarlos periódicamente**).
- **Aplicación:** validación de entrada (comprobar en el servidor que cada dato recibido tiene el formato, tamaño y rango esperado), firmas de transacción (vinculación dinámica: si alguien cambia esos datos

después de la aprobación, la firma ya no debería ser válida), protección anti-replay (impedir que una solicitud o autorización válida se reutilice) y anti-CSRF (evitar que una página maliciosa induzca al navegador de un usuario autenticado a enviar una acción no deseada); SAST (analiza el código sin ejecutarlo para buscar patrones vulnerables), DAST (prueba la aplicación mientras está en ejecución, normalmente en un entorno de pruebas, enviándole solicitudes y entradas de prueba), SCA (revisa bibliotecas y dependencias de terceros para detectar vulnerabilidades) y escaneo de imágenes en CI (inspecciona imágenes de contenedores en busca de paquetes vulnerables y errores de configuración).

- **Detección y respuesta:** GuardDuty (analiza señales de AWS, como actividad de cuentas, redes y cargas de trabajo, y genera hallazgos sobre posibles amenazas), Security Hub (reúne hallazgos de servicios de seguridad y herramientas integradas para ofrecer una vista centralizada y priorizarlos), SIEM (*Security Information and Event Management*: centraliza registros de AWS, aplicaciones y otros sistemas; correlaciona eventos para detectar patrones), alertas de anomalías (avisan cuando una actividad se aparta de un patrón esperado, como un acceso inusual o cambios sospechosos) y playbooks de incidentes (procedimientos previamente definidos para clasificar una alerta, investigar, contener el problema, recuperar el servicio y documentar lo ocurrido; algunas acciones pueden automatizarse, con controles para evitar interrupciones innecesarias).
- **Privacidad:** consentimiento (informar a la persona y obtener su autorización), minimización (recoger y usar solo los datos necesarios para una finalidad concreta), retención (conservar los datos solo durante el tiempo necesario) y derecho de supresión (permitir que la persona solicite que se eliminen sus datos cuando corresponda); evaluación de impacto (LOPDP).

14. Monitoreo y excelencia operativa

- **Métricas (golden signals):** latencia, tráfico, errores, saturación; métricas de negocio (transferencias exitosas/min).
- **Logs y trazas:** logs estructurados con `correlationId` (identificador que se propaga entre servicios para relacionar los registros de una misma solicitud), OpenTelemetry hacia X-Ray/Tempo (**preparar la aplicación para recopilar datos de funcionamiento** y exportar las trazas, métricas y registros; las trazas permiten seguir una solicitud mientras pasa por distintos servicios y ver dónde tarda o falla), dashboards en Grafana.
- **SLO (Service Level Objective) / SLI (Service Level Indicator) y alertas:** SLO de disponibilidad 99.95 %, presupuesto de error (aprox. **21,6 minutos** de indisponibilidad/mes) y alertas por *burn rate* (avisan cuando el presupuesto de error se está consumiendo demasiado rápido); escalamiento por PagerDuty/Opsgenie (envía la alerta a la persona o equipo de guardia y, si no se atiende, la escala a otros responsables según reglas).
- **Monitoreo sintético:** pruebas de transacciones simuladas desde varias regiones.
- **Entrega:** CI/CD (automatiza la integración, las pruebas y la entrega o despliegue del código), IaC (Terraform: define infraestructura como código), GitOps (Argo CD: usa el estado deseado guardado en Git como referencia), despliegues *canary* (lanza la nueva versión primero a una pequeña parte del tráfico; si las métricas son buenas, se aumenta gradualmente; si empeoran, se detiene o revierte) y *blue/green* (mantiene dos entornos, uno activo y otro con la nueva versión; tras probarlo, se cambia el tráfico al nuevo; si falla, se vuelve al anterior), feature flags (permiten activar o desactivar funciones sin desplegar otra versión del código), rollback automático (revierte el despliegue si se incumplen criterios definidos).
- **Calidad:** pruebas de contrato (Pact: verifican que un servicio y los servicios que lo consumen coinciden en el formato y comportamiento acordados de sus APIs), carga (k6: simulan tráfico para medir latencia, errores y capacidad), caos (Fault Injection/Litmus: introducen fallos controlados) y revisión de arquitectura periódica (revisa decisiones, dependencias, seguridad, costos, capacidad y recuperación ante fallos a medida que cambian el producto y sus necesidades).
- **Operación:** runbooks (guías concretas para responder a incidentes o tareas recurrentes: indican cómo reconocer el problema, qué pasos seguir, cómo validar la recuperación y cuándo escalarlo), post-mortems sin culpa (revisiones posteriores a incidentes centradas en entender qué condiciones permitieron que ocurriera el fallo y cómo evitar que se repita) y gestión de capacidad (prever si habrá suficientes recursos de cómputo, almacenamiento, conexiones, cuotas y personal operativo para la demanda prevista; incluye observar tendencias, planificar picos y probar límites).

15. Costos (estimación referencial mensual)

> Valores aproximados para dimensionar; tomar en cuenta posibles descuentos corporativos.

Métrica	Escenario base	Crecimiento x3 (24 meses)
Clientes registrados	500 mil	1.5 millones
Usuarios activos diarios	50 mil	150 mil
TPS pico	150	450

Componente	Escenario base (USD/mes)	Crecimiento 3x (USD/mes)
EKS + nodos (multi-AZ)	4,500	10,500
Aurora PostgreSQL (Multi-AZ + réplica)	3,000	6,500
ElastiCache Redis	900	1,800
MSK Kafka	1,800	3,500
API Gateway, CloudFront, WAF	1,500	3,800
Face Liveness / biometría (por transacción)	800	2,000
Notificaciones (SMS/Email/Push)	2,000	5,500
Observabilidad y seguridad	2,200	4,500
Direct Connect / red / DR warm standby	2,800	4,500
Total aproximado	**≈ 19,500**	**≈ 42,600**

Estrategias de optimización:

- Savings Plans / instancias reservadas (1–3 años) para carga base (ahorro ~30–50 %).
- Autoescalado y Spot (instancias de cómputo con capacidad disponible que puede ser interrumpida por AWS) para cargas no críticas (batch, CI *Continuous Integration*).
- Caché para reducir llamadas al core y a proveedores con costo por consulta.
- Almacenamiento por niveles: S3 Intelligent-Tiering (mueve automáticamente los objetos entre niveles de acceso cuando cambia su frecuencia de uso) / Glacier (ofrece clases de archivo para datos que se consultan rara vez) para auditoría histórica.
- Etiquetado (tagging: asignar etiquetas coherentes a los recursos, por ejemplo `equipo=pagos`, `proyecto=app-movil`, `entorno=produccion` y `centro_costo=...`; así se puede atribuir y analizar el gasto por equipo, proyecto o ambiente) y FinOps (práctica colaborativa entre ingeniería, finanzas y producto para entender, asignar y optimizar el costo de la nube sin perjudicar el servicio) con alertas de presupuesto; revisión mensual.

16. Riesgos y mitigación

Riesgo	Impacto	Mitigación
Indisponibilidad o lentitud del core	Alto	Circuit Breaker, caché, modo degradado, colas
Fraude / suplantación en onboarding	Alto	Liveness certificado, face match, validación documental, scoring de riesgo
Fuga de datos personales/biométricos	Alto	Cifrado, minimización, segregación, monitoreo, plan de respuesta
Duplicidad de transferencias	Alto	Idempotency Key, Saga, conciliación diaria
Dependencia de un proveedor de notificaciones	Medio	Dos proveedores con failover
Sobrecostos cloud	Medio	FinOps, presupuestos, autoescalado
Complejidad operativa de microservicios	Medio	Plataforma estándar, observabilidad, plantillas y GitOps
Cambios regulatorios	Medio	Diseño modular y revisión legal periódica

17. Conclusiones

La arquitectura propuesta cumple los requerimientos de BP con un diseño modular, seguro y resiliente. El uso de OAuth 2.0 Authorization Code + PKCE sobre el IAM corporativo, el onboarding biométrico con liveness, la auditoría inmutable basada en eventos y la caché para clientes frecuentes responden directamente a los puntos críticos del reto. El bus de eventos y los BFF permiten incorporar nuevos canales y servicios (por ejemplo, pagos QR, inversiones u *open banking*) con bajo impacto, mientras que la plataforma cloud multi-AZ con DR y autohealing asegura continuidad y excelencia operativa dentro de un presupuesto controlado.

Se recomienda AWS por su ventaja en biometría lista para usar, DR gestionado y latencia, pero el desacoplamiento por adaptadores y el uso de tecnologías abiertas permiten migrar a Azure con un esfuerzo moderado, concentrado en infraestructura como código y datos, sin reescribir la lógica de negocio.

Anexo A. Selección de nube: justificación de AWS vs. Azure

A.1 Por qué se recomienda AWS

Criterio	AWS (recomendado)	Azure	Impacto en la solución
Biometría facial	Rekognition Face Liveness: prueba de vida y comparación facial en el mismo ecosistema, con SDK para móvil.	Face API con Liveness disponible, pero con acceso restringido que requiere aprobación de Microsoft.	Menor fricción y tiempo de salida del onboarding.
Servicios gestionados para HA/DR	Aurora Multi-AZ y Global Database, MSK multi-AZ, ElastiCache con failover automático, todos muy maduros.	Equivalentes sólidos (Azure SQL/PostgreSQL con zonas, Event Hubs, Cache for Redis).	Ambas cumplen; AWS simplifica el DR multi-región con Aurora Global.
Latencia hacia Ecuador	Regiones en São Paulo y Virginia; edge de CloudFront en la región.	Brazil South y East US; menos puntos de presencia en la región.	Mejor latencia con CloudFront + región cercana.
Seguridad y cumplimiento	KMS, CloudHSM, GuardDuty, Security Hub, WAF/Shield; certificaciones PCI-DSS e ISO 27001.	Key Vault, Defender for Cloud, Front Door WAF; mismas certificaciones.	Paridad; AWS ofrece más controles nativos integrados en un solo plano.
Kubernetes y operación	EKS con Karpenter, IRSA.	AKS con KEDA y workload identity.	Ambas sirven para autohealing y autoescalado.
Mensajería	MSK (Kafka) y SNS/SQS para notificaciones.	Event Hubs (API Kafka) y Service Bus.	Equivalentes; ambas desacoplan productores y consumidores.
Ecosistema y talento	Mayor cantidad de arquitectos y referencias de banca en la región.	Fuerte en empresas con stack Microsoft.	Menor riesgo de contratación y soporte.

Justificaciones principales:

1. Rekognition Face Liveness reduce el riesgo y el esfuerzo del onboarding biométrico (requisito crítico del reto) sin trabajo de aprobación adicional.
2. La combinación Aurora Global Database + MSK + EKS multi-AZ permite demostrar HA, tolerancia a fallos y DR con RPO de segundos usando servicios gestionados, lo que reduce la carga operativa y el costo de personal.
3. Menor latencia con CloudFront y regiones cercanas, importante para la experiencia móvil.
4. La arquitectura se diseñó con **Kubernetes, Kafka, PostgreSQL, Redis, OpenTelemetry y Terraform**, tecnologías portables; la elección de AWS no genera dependencia de proveedor (*vendor lock-in*) en el dominio de negocio.

A.2 Mapeo de servicios AWS a Azure

Capacidad	AWS	Azure
DNS y failover global	Route 53	Azure Traffic Manager / Front Door
CDN y WAF	CloudFront + WAF + Shield	Azure Front Door + WAF + DDoS Protection
SPA estática	S3 + CloudFront	Storage Static Website / Static Web Apps + Front Door
API Gateway	Amazon API Gateway	Azure API Management (APIM)
Contenedores	EKS	AKS
Base transaccional y de auditoría	Aurora PostgreSQL	Azure Database for PostgreSQL Flexible Server (zona redundante)
Caché	ElastiCache Redis	Azure Cache for Redis (Premium / Enterprise)
Mensajería de eventos	MSK (Kafka)	Event Hubs (endpoint Kafka)
Colas y tópicos de notificaciones	SQS + SNS	Service Bus (colas y tópicos) + Notification Hubs
Almacenamiento inmutable (WORM)	S3 Object Lock	Blob Storage con inmutabilidad (WORM)
Claves y secretos	KMS, CloudHSM, Secrets Manager	Key Vault (Managed HSM)
Identidad de cargas	IRSA / IAM Roles	Workload Identity / Managed Identity
Biometría	Rekognition Face Liveness	Azure AI Face (Liveness) u otro proveedor (Onfido/Jumio)
Conectividad al core on-premise	Direct Connect + VPN, PrivateLink	ExpressRoute + VPN, Private Link
Monitoreo	CloudWatch, X-Ray, Prometheus/Grafana	Azure Monitor, Application Insights, Managed Grafana
Seguridad y detección	GuardDuty, Security Hub	Defender for Cloud, Microsoft Sentinel
IaC y automatización	Terraform, Systems Manager	Terraform, Bicep, Azure Automation
DR	Aurora Global + réplica MSK + CRR	Geo-replicación, Event Hubs Geo-DR, GRS/GZRS

A.3 Cuándo elegir Azure en lugar de AWS

- BP ya tiene contrato corporativo (EA) y créditos con Microsoft.
- El IAM corporativo es Entra ID y se desea integración nativa.
- El stack del core o del sistema complementario es .NET / SQL Server y se busca aprovechar Hybrid Benefit.
- La política de BP o del regulador prioriza una región o proveedor concreto.